Supplier CRA readiness questionnaire

Thirty-one questions in eight sections show which of the 41 in-scope suppliers can commit to vulnerability notification, SBOM delivery and support periods. Answers are scored against the risk tier of the component supplied, and the score routes each supplier to approved, approved with conditions, or exit plan.

Design

The questionnaire evidences Art 13(5) due diligence on supplied components and tells procurement which suppliers can sign the CRA clause pack as it stands.

Item	Design
Purpose	Evidence due diligence on supplied components (Art 13(5)); decide which suppliers sign the clause pack as is, which need conditions and which components need an exit plan
Audience	Suppliers of software, firmware, hardware with firmware, SaaS that a product function relies on, and development services
Sampling	Census of the 41 in-scope suppliers. Wave 1: the 15 suppliers of the highest-tier components, matching the K09 target of the top 15 on CRA clauses by Jan 2027. Wave 2: the other 26
Timing	Wave 1 issued 24 Nov 2026 with the supplier letter in the Communication Pack (D05); wave 2 to all 41 in-scope suppliers by 18 Dec 2026 (task T21). Replies due 15 Dec 2026 for wave 1 and 15 Jan 2027 for wave 2; reminders after 10 and 20 days
Length	31 questions in eight sections; about 40 minutes, longer if evidence is attached
Unit	One response per supplied component or component family
Answer aids	Every question has an optional comment field and evidence upload; "not yet" with a date is accepted where offered

Item	Design
Confidentiality	Commercially confidential under the existing non-disclosure terms; held by procurement and shared with the programme in scored form
Before sending	Procurement assigns each component a risk tier (below) and states on the cover sheet the support periods of the Example Group products that use it (5 to 12 years across the 13 families)

Diligence scales with the component's risk (Recital 34), so the tier, assigned by Example Group before sending, sets the must-pass items and thresholds in the scoring rubric.

Tier	Definition	Examples
Critical	Performs or enforces a security function, or is network-facing system software in a Class I or Class II product	Secure-boot, cryptographic and TLS libraries; cellular and Wi-Fi module firmware; embedded Linux board support packages in routers, switches and firewalls; update clients
High	Runs with privilege or parses external input in any product; is used in three or more families; is SaaS that a product function relies on; or is a build-chain tool or service that can change shipped code	Zigbee, Thread and Bluetooth stacks; companion-app SDKs; CI actions and plugins; code-signing services
Medium	Executable code with no network exposure and no privilege	Sensor and power-management firmware with no external interface; offline font or graphics libraries
Low	No executable code in the shipped product, or code isolated from data and networks	Passive components; documentation and translation services

Cover note

Procurement sends this email with the questionnaire link alongside the formal supplier letter in the Communication Pack (D05); the Head of procurement approves it and General Counsel reviews it before wave 1.

> **Subject:** EU Cyber Resilience Act: supplier questionnaire for [component], reply by [date]
>
> Dear [name],
>
> Further to our letter of [date] about the EU Cyber Resilience Act (CRA), we ask you to complete a questionnaire about [component and part numbers].
>
> The CRA makes Example Group responsible for the security of every component in the products we sell in the EU, including yours. Your answers help us agree contract terms on vulnerability notification, software bills of materials (SBOMs), support periods and evidence on request.
>
> - The questionnaire has 31 questions and takes about 40 minutes: [link].
> - Please reply by [date]. Where a question does not apply, say why in the comment field; "not yet", with a date, is a useful answer.
> - The products that use your component carry support periods of [x] years; question 5.1 asks about your commitment for that period.
> - Your answers are confidential under our agreement of [date] and are used only to assess supply-chain security and agree contract terms.
>
> [Name], [role] in Procurement, will answer any questions: [email], [phone].
>
> Kind regards,
>
> [Name], Head of procurement, Example Group

Questions

Thirty-one questions follow the eight sections of the supply-chain guide; 25 are scored, "don't know" scores 0, and points are listed in the same order as the options.

1. Identity and role (not scored)

ID	Question	Answer type and options	Points	Required
SUP-1.1	What is the legal name and country of establishment of the supplying entity?	Text	Not scored	Yes
SUP-1.2	Is the supplying entity, or an authorised representative of it, established in the EU?	Single: EU-established entity; authorised representative in the EU; neither; don't know	Not scored	Yes

ID	Question	Answer type and options	Points	Required
SUP-1.3	Which components, versions and part numbers does this response cover?	Text, one line per item	Not scored	Yes
SUP-1.4	Do you also place this component on the EU market as a product in its own right, for example a module, firmware image, library or SDK sold separately?	Single: yes; no; don't know	Not scored	Yes
SUP-1.5	If yes, which CRA category have you determined for it?	Single: default; important Class I (state the Annex III item); important Class II; critical; not yet determined	Not scored	If 1.4 is yes

2. Conformity

ID	Question	Answer type and options	Points	Required
SUP-2.1	What is the status of the component's EU declaration of conformity under the CRA?	Single: issued; planned before 11 Dec 2027 (give the date); not planned; don't know. Text: notified body and module, if any	2; 1; 0; 0	If 1.4 is yes
SUP-2.2	Which security standards or certifications apply to the component, and with what scope?	Multi: IEC 62443-4-1; IEC 62443-4-2; EN 18031-1, -2 or -3; ETSI EN 303 645; Common Criteria or EUCC (state the level); ISO/IEC 27001 (state the scope); other; none. Text: scope statement	2 = a product-level standard or certificate with its scope stated; 1 = organisation-level only, such as ISO/IEC 27001; 0 = none	Yes

ID	Question	Answer type and options	Points	Required
SUP-2.3	If the component is open-source software you place on the market in an Annex III category, is its Annex VII technical documentation public, as Art 32(5) requires for self-assessment?	Single: yes (give the URL); no; not applicable	Not scored	If applicable

3. Vulnerability handling

ID	Question	Answer type and options	Points	Required
SUP-3.1	Do you publish a coordinated vulnerability disclosure (CVD) policy and a security contact, such as a security.txt file?	Single: both published (give the URLs); policy only; contact only; neither; don't know	2; 1; 1; 0; 0	Yes
SUP-3.2	Who triages vulnerability reports for this component?	Single: a dedicated PSIRT; a named function within engineering; no defined owner; don't know	2; 1; 0; 0	Yes
SUP-3.3	What are your target times, in calendar days, to acknowledge a vulnerability report and to fix or mitigate a critical vulnerability?	Two numbers: acknowledge; fix or mitigate	2 = acknowledgement within 7 days and a fix target stated; 1 = targets stated, acknowledgement over 7 days; 0 = no targets	Yes

ID	Question	Answer type and options	Points	Required
SUP-3.4	Will you notify Example Group, without undue delay and through a named channel, of vulnerabilities in the component, with the affected versions and available fixes?	Single: yes, already in our contract; yes, we will accept the clause; only for critical vulnerabilities; no; don't know	2; 2; 1; 0; 0	Yes
SUP-3.5	In what form do you publish security advisories for the component?	Single: machine-readable (CSAF) and human-readable; human-readable only; on request only; none; don't know	2; 1; 0; 0; 0	Yes

The 7-day acknowledgement in SUP-3.3 follows draft prEN 40000-1-3 as reported by ENISA (a draft, not cited); BSI TR-03183-3 uses 5 working days (non-binding).

4. SBOM

ID	Question	Answer type and options	Points	Required
SUP-4.1	Will you deliver a machine-readable SBOM with each release of the component you deliver to us?	Single: yes, already; yes, from a date (give it); on request only; no; don't know	2; 1; 1; 0; 0	Yes
SUP-4.2	Which SBOM format and version do you use?	Single: CycloneDX 1.6 or later; SPDX 3.0.1 or later; an earlier CycloneDX or SPDX version; other; don't know	2; 2; 1; 0; 0	Yes
SUP-4.3	How deep does the SBOM go?	Single: all transitive dependencies, with completeness marked and known unknowns declared; direct dependencies only; varies by release; don't know	2; 1; 0; 0	Yes

ID	Question	Answer type and options	Points	Required
SUP-4.4	How is the SBOM generated?	Single: at build time from the delivered artefact; from source manifests; manually; don't know	2; 1; 0; 0	Yes

5. Support

ID	Question	Answer type and options	Points	Required
SUP-5.1	Until when will you provide security updates for the component version you supply?	Date. Then single: covers the support period on the cover sheet; shorter, but at least five years; shorter than five years; no commitment; don't know	2; 1; 0; 0; 0	Yes
SUP-5.2	How do you deliver security updates for the component?	Single: signed, through a defined channel, with release notes; unsigned, through a defined channel; ad hoc on request; no updates; don't know	2; 1; 0; 0; 0	Yes
SUP-5.3	Can you ship security fixes separately from feature changes?	Single: yes, always; yes, where technically feasible; no; don't know	2; 2; 0; 0	Yes
SUP-5.4	How much notice will you give before the component reaches end of support or is withdrawn?	Single: 24 months or more; 12 to 23 months; under 12 months; no commitment; don't know	2; 1; 0; 0; 0	Yes
SUP-5.5	Will you agree cessation arrangements: notice before ceasing operations, and escrow or transfer of what we need to keep the component updated?	Single: yes, escrow already in place; yes, we will agree them; no; don't know	2; 1; 0; 0	Yes

6. Secure development

ID	Question	Answer type and options	Points	Required
SUP-6.1	Which secure development framework governs the component?	Single: IEC 62443-4-1, certified or independently assessed; IEC 62443-4-1, NIST SSDF or OWASP SAMM, self-assessed; another documented lifecycle; none; don't know	2; 1; 1; 0; 0	Yes
SUP-6.2	Which security tests run on each release of the component?	Multi: static analysis; software composition analysis; fuzzing; dynamic testing; penetration testing (state how often); none	2 = three or more, including composition analysis; 1 = one or two; 0 = none	Yes
SUP-6.3	How are release artefacts signed?	Single: signed, keys in an HSM or equivalent hardware; signed, keys in software; not signed; don't know	2; 1; 0; 0	Yes
SUP-6.4	Do you produce build provenance for releases, such as SLSA-style attestations?	Single: yes; planned (give the date); no; don't know	2; 1; 0; 0	Yes

7. Incident and reporting posture

ID	Question	Answer type and options	Points	Required
SUP-7.1	If you learn that a vulnerability in the component is being actively exploited, how quickly will you tell us?	Single: within 24 hours; within 72 hours; within 7 days; no commitment; don't know	2; 1; 0; 0; 0	Yes

ID	Question	Answer type and options	Points	Required
SUP-7.2	How quickly will you tell us about a security incident in your development, build or update infrastructure that could affect the component, such as a compromised signing key?	Single: within 24 hours; within 72 hours; later or without a time commitment; we would not; don't know	2; 1; 0; 0; 0	Yes
SUP-7.3	Will you coordinate disclosure with us: embargo, advisory timing, CVE or EUVD identifiers and who informs users?	Single: yes; case by case; no; don't know	2; 1; 0; 0	Yes

8. Evidence available on request

ID	Question	Answer type and options	Points	Required
SUP-8.1	Which evidence can you provide on request?	Multi: EU declaration of conformity; technical documentation extracts; risk assessment extract; test reports (penetration, fuzzing); certificates with scope statements; none	2 = three or more, including test reports; 1 = one or two; 0 = none	Yes
SUP-8.2	When a market surveillance authority or notified body asks us for evidence about the component, how quickly can you supply your part?	Single: within 5 working days; within 10 working days; longer; we would not supply it; don't know	2; 1; 0; 0; 0	Yes

Five working days leaves time to meet Example Group's target of answering a reasoned request within 10 working days (Q9.4 in the diagnostic).

Scoring rubric

The route depends on the component's tier: the score measures overall comfort, and the must-pass items set a floor that no total can offset.

- **Score.** Points divided by the maximum for the scored questions that apply: 25 questions and 50 points, or 24 and 48 when SUP-2.1 does not apply. Section scores are kept for the supplier's profile.
- **Must-pass items** must score 2. An item at 1 counts only with a dated commitment; without one it counts as 0.

Tier	Must-pass items
Critical	3.1 CVD policy and contact; 3.4 vulnerability notification; 4.1 SBOM per release; 5.1 support covers our period; 7.1 exploited vulnerabilities reported within 24 hours; 8.2 evidence within 5 working days
High	3.1; 3.4; 4.1; 5.1
Medium	3.4; 5.1
Low	3.4

Tier	Approved	Approved with conditions	Exit plan
Critical	Score of 80% or more and every must-pass item met	Score of 60–79%, or must-pass items at 1 with a dated commitment before 30 Jun 2027	Score below 60%, any must-pass item at 0, or the notification clause refused
High	70% or more and every must-pass item met	50–69%, or must-pass items at 1 with a dated commitment before 30 Jun 2027	Below 50%, any must-pass item at 0, or the notification clause refused
Medium	60% or more and every must-pass item met	40–59%, or a must-pass item at 1 with a dated commitment	Below 40% with a must-pass item at 0, or the notification clause refused
Low	40% or more	Below 40%	The notification clause refused

The 30 Jun 2027 deadline matches the K09 target of all in-scope suppliers on CRA clauses by Jun 2027.

- **Approved.** The supplier signs the standard clause pack; the answers are re-checked at renewal or within 24 months.
- **Approved with conditions.** Dated conditions go into the contract or an addendum and are checked on their due date; a missed condition moves the component to an exit plan.
- **Exit plan.** The component enters the intake gate as high risk, with a documented mitigation (own binary composition analysis, sandboxing or an alternative supplier) and an exit plan with an owner and a date.
- **No response** after two reminders sends Critical and High components to an exit plan and Medium and Low components to conditions.
- **Verification.** Before approving a Critical component, the programme checks three answers against evidence: a sample SBOM, the CVD policy URL and a signed release.
- **Illustration (hypothetical).** A Critical-tier cellular module scores 78% and answers 4.1 with SBOM delivery from 1 Mar 2027. It is approved with conditions, and the SBOM date is written into the addendum.

How results feed the programme

Wave 1 results reach the supplier risk register by 18 Dec 2026, in time for clause negotiations with the top 15 suppliers in January.

- **Supplier risk register.** One row per supplier and component: tier, score, must-pass status, route, conditions, owner and review date (shell in tab 8). Owned by WS5.
- **K09.** In-scope suppliers on CRA clauses stood at 6 of 41 on 30 Oct 2026, against targets of the top 15 by Jan 2027 and all by Jun 2027. Approved and conditioned suppliers move to signature first.
- **Intake gate.** Exit-plan components enter as high risk.
- **R04 and issue I03.** Answers to 4.1 to 4.4 show where supplier SBOMs fall short and size the binary composition analysis needed on HBS firmware.
- **Article 14 readiness.** Answers to 3.4 and 7.1 update the supplier contacts in the PSIRT runbook; the next drill (M9, 16 Apr 2027) tests an unresponsive supplier.
- **Conformity files.** Answers to 8.1 and 8.2 tell the Module H and Module B+C files which supplier evidence exists.

Project Rampart · Survey and Interview Instruments (D07) · Illustrative · 31 Oct 2026